MANDALUYONG COLLEGE OF SCIENCE AND TECHNOLOGY
Bachelor of Science in Information Systems

INFORMATION TECHNOLOGY AUDIT REPORT

Student Profiling and Early Warning System (SPEWS)

Office of Student Affairs (OSA)

Professional Audit Report — Final Integrated Report (Labs 7–12)

Lab 12: AI Validation Portfolio and Final Report Integration

Audit Team / Group No.: PCM

Capstone System / Build: SPEWS | Current PCM Prototype | Local XAMPP/PHP/MySQL Demo

Partner Organization: Office of Student Affairs (OSA)

Member 1 / Role: Russel A. Cabaluna | Engagement Partner and Final Editor
Member 2 / Role: Ghyn Aedrianne Mendoza | Quality and Traceability Reviewer
Member 3 / Role: Jasmin T. Pille | AI Validation and Evidence Custodian

DOCUMENT CONTROL AND VERSION HISTORY

Version	Date	Lab / Increment	Prepared By	Reviewed By	Change Summary
0.1	9/19/2026	Lab 8 / Increment 2	Cabaluna, Mendoza	Cabaluna, Mendoza	Added System Documentation and Asset Baseline
0.3	9/26/2026	Lab 9 / Increment 3	Cabaluna, Mendoza, Pille	Cabaluna, Mendoza, Pille	Added Risk Register and Compliance Mapping
0.4	10/3/2026	Lab 10 / Increment 4	Cabaluna, Mendoza, Pille	Cabaluna, Mendoza, Pille	Added Control Test Results and Gap Analysis
0.5	10/10/2026	Lab 11 / Increment 5	Cabaluna, Mendoza, Pille	Cabaluna, Mendoza, Pille	Added Findings, Recommendations, and Action Plan
1.0 Final	10/17/2026	Lab 12 / Final	Cabaluna, Mendoza, Pille	Cabaluna, Mendoza, Pille	Integrated final report, AI validation portfolio, traceability, and attestation

Final Audit Report Build Register

Lab	Report Section	Status	Version / Date	Instructor Action
7	Engagement Profile and Scope	Completed	v0.1 / 9/12/2026	
8	Asset Inventory and System Documentation	Completed	v0.1 / 9/19/2026	
9	Risk and Compliance Assessment	Completed	v0.3 / 9/26/2026	
10	Control Assessment and Gap Analysis	Completed	v0.4 / 10/3/2026	
11	Audit Findings and Recommendations	Completed	v0.5 / 10/10/2026	
12	AI Validation Portfolio and Final Report Integration	Completed	v1.0 / 10/17/2026	

Prior Feedback Closure

Feedback ID	Prior Instructor Comment / Required Revision	Action Taken	Section / IDs Affected	Closed By / Date
FB-10-01				
FB-11-01				
FB-12-01				
FB-13-01				
FB-14-01				

Finalization Control

Field	Entry	Action Taken	Section / IDs Affected	Closed By / Date

Final Report Version	1.0 Final			
Final Audited Build / Environment	SPEWS Current PCM Prototype	Local XAMPP/PHP/MySQL Demo		
Audit and Evidence Cutoff	10/17/2026			
Report Date	10/17/2026			
Changes After Cutoff				
Overall Conclusion Rating	Needs Improvement			
Finding Totals	Critical 0	High 3	Moderate 2	
Risk Totals	Critical 0	High 4	Moderate 4	
Confidentiality Classification	Academic / Sanitized			

Final Revision and Exception Log

QA ID	Issue / Required Revision	Source	Action Taken	Affected Sections / IDs	Resolved By / Date	Status
QA-01	Ensure no real student data is in the report	Member check	Replaced all real data with dummy or sanitized examples	FND-01 to FND-05	Pille / 10/16/2026	Closed
QA-02	Fix table of contents and page numbers	Final Editor	Updated Word document fields	Master Report	Cabaluna / 10/17/2026	Closed
QA-03	Verify ID consistency across all registers	Traceability Reviewer	Cross-checked AST, RSK, CTL, TEST, GAP, FND, REC IDs	All sections	Mendoza / 10/17/2026	Closed
QA-04	Confirm AI register completeness	AI Custodian	Added AI-14-01 and reconciled AI-10-01 to AI-13-03	Section C.1	Pille / 10/17/2026	Closed

1. EXECUTIVE SUMMARY AND OVERALL CONCLUSION

This audit examined the Student Profiling and Early Warning System (SPEWS) of the MCST Office of Student Affairs (OSA). The objective was to determine whether SPEWS protects student data, maintains accurate records, and operates consistently with its documented design in the audited prototype build. The team used document reviews, walkthroughs, inspections, and non-destructive functional testing with dummy data.

Overall Audit Conclusion: Needs Improvement. SPEWS is functional and supports OSA's core monitoring process. However, the audit identified five formal findings: three High and two Moderate. The most significant risks are the absence of Multi-Factor Authentication (MFA) for privileged accounts, the lack of a database backup tool, and a partial Python analytics tool that may misclassify at-risk students. Two additional items—audit log integrity and export controls—were disclosed as observations because evidence was insufficient for formal findings. The team recommends that OSA prioritize MFA and backup capability within 30–60 days, complete and test the Python analytics tool before full use, and establish a data retention policy and privacy notice within 90 days.

Priority Action Roadmap

Priority	FND / REC	Action	Accountable Role	Target / Trigger	Expected Risk Reduction	Follow-Up Evidence
Immediate	FND-01 / REC-01	Add MFA and account lockout rules	OSA Head	Within 30 days	Prevents stolen passwords from being used	Screenshot of MFA and lockout settings
High	FND-03 / REC-03	Build backup tool (MOD-07) and test restore	OSA Head	Within 60 days	Prevents permanent data loss	Backup log and restore test record
High	FND-02 / REC-02	Complete Python analytics tool and add manual review	OSA Head	Within 60 days	Ensures at-risk students are identified correctly	Python tool test results and review log
Medium	FND-04 / REC-04	Write data retention and disposal policy	OSA Head	Within 90 days	Ensures lawful retention and disposal	Approved policy document
Medium	FND-05 / REC-05	Create and issue privacy notice	OSA Head	Within 90 days	Students are informed of data use	Copy of issued privacy notice

2. ENGAGEMENT PURPOSE, OBJECTIVES, SCOPE, CRITERIA, METHODOLOGY, LIMITATIONS

2.1 Engagement Profile

Field	Entry
Organization	Mandaluyong College of Science and Technology (MCST)
Capstone System	An Intelligent Student Profiling and Early Warning System for the MCST Office of Student Affairs (SPEWS)

Business Purpose	Centralize student records and help OSA monitor attendance, violations, at-risk students, interventions, and reports
Reporting Audience	Research Adviser, Capstone Professor, Panelists, and authorized OSA personnel
Authorized Engagement Contact	Office of Student Affairs (OSA)
Authorization Limits	Review the working SPEWS prototype using authorized accounts and dummy data; non-destructive testing only
Submission Restrictions	Dummy or sanitized data only; no passwords, credentials, confidential student information, or unrestricted production records
Audited Build / Version	Current SPEWS Capstone Prototype (PCM development build)
Environment	Local development environment using XAMPP, PHP, and MySQL
Planned but Not Implemented	Python-based 20% attendance calculation and Low/Medium/High classification (partial); database backup functionality (not implemented)

2.2 Audit Objectives

OBJ ID	Audit Objective Statement	Criterion	Intended Result
OBJ-01	Assess whether SPEWS authentication and role-based access provide users only the functions appropriate to their roles.	CRT-01 — Role-based access requirements	Determine whether access design and role separation are defined and enforced
OBJ-02	Evaluate whether implemented modules operate consistently with the documented process and scope.	CRT-02 — Capstone design specification	Confirm functions available for audit and identify limitations
OBJ-03	Assess whether attendance, violation, and intervention records are processed and linked correctly.	CRT-03 — Documented system rules	Determine whether core transactions are traceable and controlled
OBJ-04	Evaluate whether reporting, export, and audit-trail functions provide accountable outputs.	CRT-04 — Reporting and logging requirements	Determine whether outputs and accountability are adequate
OBJ-05	Assess whether privacy obligations under RA 10173 are addressed in the audited build.	CMP-01 to CMP-07 — DPA requirements	Determine compliance status and gaps

2.3 Scope Boundaries

SCP ID	Related OBJ	Boundary Dimension	Decision	Specific Area / Item	Limitation or Restriction
SCP-01	OBJ-01	Organization and users	In Scope	OSA Head, OSA Staff, Chairperson, Faculty, Security Guard,	Sanitized access evidence only

				authorized technical support	
SCP-02	OBJ-02	Process and function	In Scope	Login, student profiles, attendance, violations, at-risk/intervention, reports/export, audit trail	MOD-03 is partial; Python calculation not complete
SCP-03	OBJ-03	Technology and environment	Limitation	Local XAMPP/PHP/MySQL prototype and Python analytics	Conclusions limited to prototype environment
SCP-04	OBJ-04	Data and time	Limitation	Dummy/sanitized data for the evidence period	No unrestricted production records
SCP-05	OBJ-05	Procedure	In Scope	Inquiry, inspection, walkthrough, observation, controlled functional testing	No scanning, exploitation, or system changes
SCP-06	—	Process and function	Out of Scope	Database backup/recovery functionality	Disclose as planned/not implemented
SCP-07	—	Process and function	Limitation	Python-based attendance calculation and classification	Do not represent as fully implemented
SCP-08	—	Technology and environment	Out of Scope	Production vulnerability scanning, exploitation, infrastructure testing	No production vulnerability conclusion supported

2.4 Methodology

The team applied the following procedures: (1) document review of the capstone design specification, Lab 7 scope workbook, and system documentation; (2) walkthroughs of implemented modules using authorized dummy accounts; (3) inspection of configuration, role matrices, and evidence screenshots; (4) controlled non-destructive functional tests of input validation, role restrictions, and report generation; and (5) reperformance of selected tests by a second team member. All evidence was sanitized before inclusion.

2.5 Limitations

- The audited build is a capstone prototype; results may not reflect a production deployment.
- The Python analytics component is partial; attendance classification conclusions are limited.
- Backup functionality is not implemented; backup effectiveness could not be tested

- No production records or historical data were accessed.
- Screenshots may not show complete history or configuration.

3. ORGANIZATION/SYSTEM CONTEXT, ASSETS, ARCHITECTURE, DATA FLOWS, ACCOUNTS

Section	Entry
Sector / Organization Type	Higher Education Institution
Relevant Unit	Office of Student Affairs (OSA)
Main Stakeholders	OSA Head, OSA Staff, Chairpersons, Faculty, Security Guards
Business Process Supported	Student profiling, attendance monitoring, violation recording, at-risk monitoring, intervention tracking, reporting, transaction logging
Process Trigger	Student record updates, attendance recording, violation recording, or at-risk identification
Major Activities	Manage student records, record attendance, record violations, identify at-risk students, assign interventions, generate reports, track transactions
Decision Points	Attendance status, at-risk identification, violation handling, intervention assignment, report review
System Inputs	Student ID, name, year, program, attendance records, violation information, intervention information, user activity
System Outputs	Dashboards, at-risk records, attendance records, violation records, intervention records, transaction logs, Excel reports
Intended Business Value	Centralized student monitoring and improved identification of students requiring intervention

3.2 Asset Inventory

AST ID	Asset / Component	Type	Purpose / Related MOD	Owner / Custodian	Location / Environment	Status	Criticality / Sensitivity
AST-01	XAMPP Local Server	HW / SW	Hosts SPEWS prototype (MOD-01 to MOD-06)	OSA Head	Local development machine	Active	High / Internal
AST-02	SPEWS Application Source Code	SW	Implements in-scope modules (MOD-01 to MOD-06)	OSA Head	Local XAMPP htdocs	Current PCM build	High / Internal
AST-03	MySQL Database	Data Store	Stores student, attendance, violation, intervention, audit data	OSA Head	Local XAMPP	Active	High / Confidential
AST-04	Student Profile Data	Data	Student identity and	OSA Head	MySQL	Active	High / Confidential

			academic information				
AST-05	Attendance Records	Data	Attendance entries and status	OSA Head	MySQL	Active	High / Confidential
AST-06	Violation Records	Data	Violation details linked to students	OSA Head	MySQL	Active	High / Confidential
AST-07	Intervention Records	Data	Intervention details and status	OSA Head	MySQL	Active	High / Confidential
AST-08	Audit Trail Logs	Data	System activity logs	OSA Head	MySQL	Active	High / Internal
AST-09	Excel Export Files	Output	Generated reports saved locally	OSA Head	Local file system	Active	High / Confidential
AST-10	Python Analytics Component	SW	Attendance calculation and classification	Development Team	Local process	Partial / In Progress	High / Internal
AST-11	Database Backup	SW / Process	Planned backup capability (MOD-07)	OSA Head	Not implemented	Planned	High / Internal

3.3 Architecture and Dependencies

DEP ID	Source / Component	Destination	Direction / Channel	Purpose / Data	Trust Boundary?	Evidence / Assumption
DEP-01	USR-01 to USR-04 (Browser)	AST-02 SPEWS Application	Inbound / HTTPS (local)	Login and user input (MOD-01)	Yes — user to system	EVD-01
DEP-02	AST-02 SPEWS Application	AST-03 MySQL Database	Outbound / Local socket	Data storage and retrieval (MOD-02 to MOD-06)	Yes — app to data	EVD-02
DEP-03	AST-02 SPEWS Application	AST-10 Python Analytics	Outbound / Local process	Attendance calculation (MOD-03)	Yes — app to analytics	Assumption: integration partial
DEP-04	AST-03 MySQL Database	AST-02 SPEWS Application	Inbound / Local socket	Query results for display	Yes — data to app	EVD-02

				and reporting		
DEP-05	AST-02 SPEWS Application	AST-09 Excel Export	Outbound / File generation	Report export (MOD-06)	Yes — app to output	EVD-06
DEP-06	AST-02 SPEWS Application	AST-08 Audit Trail Logs	Outbound / Local write	Activity logging (MOD-06)	Yes — app to log	EVD-06
DEP-07	AST-02 SPEWS Application	AST-11 Database Backup	Outbound / Local process	Planned backup (MOD-07)	Yes — app to backup	Assumption: not implemented

3.4 Data-Flow Register

FLOW ID	Transaction / Journey	Actor / Source	Validation / Processing	Store / Destination	Retention / Disposal	Related IDs
FLOW-01	User login and authentication	USR-01 to USR-04	Credential validation (MOD-01)	AST-03 MySQL	Session-based	MOD-01, ACC-01, EVD-01
FLOW-02	Student profile creation/update	USR-01, USR-02	Input validation; role check (MOD-02)	AST-04 Student Profile Data	Retained per institutional policy; sanitized	MOD-02, ACC-02, EVD-02
FLOW-03	Attendance recording	USR-03 Faculty	Attendance rules; role check (MOD-03)	AST-05 Attendance Records	Retained per institutional policy; Python calculation partial	MOD-03, ACC-03, EVD-03
FLOW-04	Violation recording	USR-04 Security Guard	Student ID validation; role check (MOD-04)	AST-06 Violation Records	Retained per institutional policy; sanitized	MOD-04, ACC-04, EVD-04
FLOW-05	At-risk identification and intervention	USR-01, USR-02	Attendance/violation review (MOD-05)	AST-07 Intervention Records	Retained per institutional policy; dummy data	MOD-05, ACC-05, EVD-05
FLOW-06	Report generation and Excel export	USR-01, USR-02	Report filter validation; role check (MOD-06)	AST-09 Excel Export	Temporary; sanitized exports	MOD-06, ACC-06, EVD-06
FLOW-07	Audit trail logging	System (automated)	Activity capture (MOD-06)	AST-08 Audit Trail Logs	Retained for accountability; sanitized	MOD-06, ACC-07, EVD-06

3.5 Account and Privilege Inventory

ACC ID	Account Type / Role	Related USR / ORG	Authentication	Privilege / Access	Provision / Approval	Review / Deactivate	Evidence / Concern
ACC-01	Administrative user	USR-01 / ORG-01	Username + password	Add, edit, view, delete authorized records	OSA Head approval	Periodic review by OSA Head	EVD-10-01; broad access requires

				(MOD-02, MOD-04, MOD-05, MOD-06)			attributable actions
ACC-02	Staff user	USR-02 / ORG-02	Username + password	Add, edit, view authorized records (MOD-02, MOD-04, MOD-05, MOD-06)	OSA Head approval	Periodic review by OSA Head	EVD-10-01; no unnecessary admin privileges
ACC-03	Faculty user	USR-03 / ORG-03	Username + password	Add, edit, view, delete attendance records (MOD-03)	OSA Head approval	Periodic review by OSA Head	EVD-10-03; access limited to attendance
ACC-04	Security Guard user	USR-04 / ORG-04	Username + password	Record student ID and violation information (MOD-04)	OSA Head approval	Periodic review by OSA Head	EVD-10-04; restricted to violation entry
ACC-05	Database service account	AST-03 / ORG-01	Local MySQL authentication	Read/write access to SPEWS database	System configuration	N/A — local prototype	EVD-10-02; credentials not submitted
ACC-06	Python analytics service	AST-10 / ORG-03	Local process execution	Attendance calculation (MOD-03)	Development team	N/A — in progress	Partial implementation; not fully auditable
ACC-07	Audit/logging service	AST-08 / ORG-01	System-internal	Write audit trail entries (MOD-06)	System configuration	N/A — automated	EVD-10-06; integrity depends on DB controls

3.6 System Modules

MOD ID	Module / Function	Purpose	Build Status	User Groups	Data Categories	Environment	MOD ID
MOD-01	Login / Authentication	Controls user access based on authorized accounts and roles	Implemented	USR-01 to USR-04	User accounts, login activity	Local XAMPP	MOD-01
MOD-02	Student Profile Management	Maintains student profile information	Implemented	USR-01, USR-02	Student ID, name, year, program	Local XAMPP	MOD-02
MOD-03	Attendance	Records and manages attendance	Partial	USR-01, USR-02, USR-03	Student ID, attendance	Local XAMPP	MOD-03

	Management				records, course information		
MOD-04	Violation Management	Records and manages violations	Implemented	USR-01, USR-02, USR-04	Student ID, violation type, details	Local XAMPP	MOD-04
MOD-05	At-Risk and Intervention Monitoring	Displays at-risk information and records interventions	Implemented	USR-01, USR-02	Attendance indicators, violation information, intervention records	Local XAMPP	MOD-05
MOD-06	Reports and Excel Export / Audit Trail	Generates reports and records activities	Implemented	USR-01, USR-02	Student, attendance, violation, intervention, audit-log data	Local XAMPP	MOD-06
MOD-07	Database Backup	Provides backup capability	Planned	—	Database backup data	Not implemented	MOD-07

4. RISK AND COMPLIANCE ASSESSMENT

4.1 Risk Scoring Method

Element	Definition				
Likelihood Scale	1 Rare	2 Unlikely	3 Possible	4 Likely	5 Almost Certain
Impact Scale	1 Insignificant	2 Minor	3 Moderate	4 Major	5 Severe
Risk Formula	Likelihood × Impact				
Risk Bands	1–4 Low	5–9 Moderate	10–16 High	17–25 Critical	

4.2 Risk Register

RSK ID	Risk Scenario	Affected IDs	Inherent L/I/Score	Existing Safeguards	Residual L/I/Score	Owner	Treatment / Priority
RSK-01	Wide add/edit/delete access may allow unauthorized changes not traceable to one person	AST-04, AST-06, AST-07, USR-01, USR-02, ACC-01, ACC-02, MOD-02, MOD-04, MOD-05	4/4/16	Role-based access; login and activity logged (MOD-06); OSA Head approves accounts	3/4/12	OSA Head	Mitigate / High
RSK-02	Partial Python attendance tool	AST-10, AST-05,	4/4/16	Manual review by OSA Staff;	4/4/16	OSA Head	Mitigate / High

	may misclassify at-risk students, causing missed interventions	MOD-03, USR-03, ACC-03, ACC-06		attendance data saved in MySQL			
RSK-03	No backup tool means system crash or data damage can cause permanent loss of records	AST-03, AST-11, MOD-07, DATA (all)	3/5/15	None; only local XAMPP	3/5/15	OSA Head	Mitigate / High
RSK-04	Password-only login allows stolen passwords to access or change private records	ACC-01, ACC-02, ACC-05, MOD-01, USR-01, USR-02, FLOW-01	3/5/15	Passwords hashed; roles limit post-login actions	3/5/15	OSA Head	Mitigate / High
RSK-05	Local MySQL without verified encryption at rest may expose confidential student information	AST-03, AST-04, AST-06, AST-07, ACC-05, FLOW-02, FLOW-04, FLOW-05	3/4/12	Local environment only; ACC-05 has read/write but no credentials submitted	3/4/12	OSA Head	Mitigate / Medium
RSK-06	Audit trail logs stored in same MySQL database may be altered or deleted by DB-level users	AST-08, ACC-05, ACC-07, MOD-06, FLOW-07	3/4/12	System logs itself; login and activity logged	3/3/9	OSA Head	Mitigate / Medium
RSK-07	Excel exports saved locally may disclose sensitive data if unprotected or accessed by unauthorized users	AST-09, MOD-06, USR-01, USR-02, FLOW-06	3/4/12	Roles limit who can export; exports sanitized in evidence	3/3/9	OSA Head	Mitigate / Medium
RSK-08	No documented retention or disposal policy means records may be kept longer than necessary	AST-04, AST-05, AST-06, AST-07, DATA (all), FLOW-02 to FLOW-05	3/3/9	None written	3/3/9	OSA Head	Mitigate / Medium

4.3 Compliance Obligations Matrix

CMP ID	Source	Exact Requirement / Section	Why Applicable	Owner	Required Evidence	Current Status	Related RSK	Gap / Action
CMP-01	RA 10173 IRR	Section 20 — Security of Personal Informatio	SPEWS handles student personal data	OSA Head	Access policy, encryption proof, logs,	Partial	RSK-01, RSK-04, RSK-05, RSK-06	No MFA, no encryption proof, log integrity not

		n: reasonable organizational, physical, and technical security			security setup			checked. Action: add MFA, document encryption, check logs
CMP-02	RA 10173 IRR	Section 11 — Transparency: tell people why their data is collected	Student data collected for profiling, attendance, violations, interventions	OSA Head	Privacy notice, collection text, purpose statement	Not Determined	RSK-08	No privacy notice issued. Action: create and issue privacy notice
CMP-03	RA 10173 IRR	Section 16 — Rights of Data Subjects: right to access, correct, object	Students have the right to see and fix their records	OSA Head	Request flow, correction process, system functions	Not Determined	RSK-01, RSK-08	No written rights process. Action: write access/correction flow
CMP-04	RA 10173 IRR	Section 20 — Retention and Disposal: do not keep personal data longer than needed	Student records kept in system	OSA Head	Retention policy, disposal process, archive/delete function	Not Determined	RSK-08	No retention or disposal policy. Action: create retention schedule and disposal process
CMP-05	MCST OSA access policy	User access must match assigned role and allowed functions	SPEWS uses role-based access	OSA Head	Role matrix, approval record, review proof	Partial	RSK-01, RSK-04	Roles in place, but wide access and no MFA. Action: review access often and add MFA
CMP-06	Capstone requirements / design spec	What is built should match declared scope and current build status	MOD-03 partial; MOD-07 planned	OSA Head	Build freeze note, module status list	Partial	RSK-01, RSK-04	Python and backup incomplete. Action: disclose as limitations
CMP-07	Capstone requirements /	Reports and exports limited to allowed roles;	MOD-06 makes reports, exports, audit logs	OSA Head	Export logs, audit samples, role permissions	Partial	RSK-06, RSK-07	Log integrity not checked; export rules not written.

	design spec	actions logged						Action: check logs and write export rules

4.4 Privacy Protection Assessment

Privacy Area	Applicable DATA / FLOW	Expected Practice	Evidence	Status	Risk / Required Action
Transparency / Purpose	AST-04 to AST-07; FLOW-02 to FLOW-05	Tell students why data is collected and how it is used	No privacy notice	Not Determined	RSK-08 — Create and issue privacy notice
Data Minimization	AST-04, AST-06, AST-07	Collect only what is needed	Student ID, name, year, program, violation details, interventions	Not Determined	RSK-08 — Review fields; remove unneeded data
Access	AST-04, AST-06, AST-07; ACC-01, ACC-02	Limit personal records to roles that need them	Role matrix; ACC-01, ACC-02 wide access	Partial	RSK-01 — Review access; apply least privilege
Security	AST-03, AST-04, AST-06, AST-07; FLOW-02, FLOW-04, FLOW-05	Protect records in storage, access, transmission, backup, export	Local MySQL; no encryption proof; no backup	Partial	RSK-03, RSK-04, RSK-05 — Add backup, MFA, document encryption
Retention	AST-04, AST-05, AST-06, AST-07	Clear reason and time for keeping records	No retention policy	Not Determined	RSK-08 — Create retention and disposal policy
Disclosure / Sharing	AST-09; FLOW-06	Control exports and limit to allowed users	Export exists; no export rules written	Partial	RSK-07 — Write export rules and log exports
Data Subject Rights	AST-04, AST-06, AST-07	Students can see and fix their records	No process written	Not Determined	RSK-08 — Write access/correction flow
Incident Handling	AST-08; MOD-06	Detect, report, record, respond to incidents	Audit logs exist; no incident process written	Not Determined	RSK-06 — Write incident response process and check log integrity

4.5 Risk Treatment and Audit Priority

RSK ID	Treatment	Proposed Action	Action Owner	Target / Trigger	Expected Residual Risk	Audit Test Priority	Rationale
RSK-01	Mitigate	Add MFA for privileged users; review access often; check audit trail completeness	OSA Head	Within 30 days	2/4/8	High	Wide admin access and weak accountability affect private records
RSK-02	Mitigate	Complete Python tool; test 20% and Low/Medium/High rules	OSA Head	Before next semester	2/3/6	High	Partial tool may cause missed interventions
RSK-03	Mitigate	Build backup tool (MOD-07); test restore	OSA Head	Within 60 days	2/4/8	High	No backup means permanent data loss risk

RSK-04	Mitigate	Add MFA for all privileged accounts; strengthen password rules	OSA Head	Within 30 days	2/4/8	High	Password-only login is a single point of failure
RSK-05	Mitigate	Document and add encryption at rest for MySQL; limit local access	OSA Head	Within 60 days	2/3/6	Medium	Private data stored without proven encryption
RSK-06	Mitigate	Check log integrity; limit database access to service account only	OSA Head	Within 60 days	2/3/6	Medium	Logs depend on unchecked DB controls
RSK-07	Mitigate	Write export rules; log all exports; limit export to allowed roles	OSA Head	Within 30 days	2/3/6	Medium	Exported files could leak private data
RSK-08	Mitigate	Create retention and disposal policy; write rights process; issue privacy notice	OSA Head	Within 90 days	2/3/6	Medium	No retention policy creates privacy risk

5. CONTROL ASSESSMENT, TEST RESULTS, AND GAP ANALYSIS

5.1 Control Inventory

RSK ID	Treatment	Proposed Action	Action Owner	Target / Trigger	Expected Residual Risk	Audit Test Priority	Rationale
CTL-01	Centralized student profile module stores and manages complete student records; login required before any action	RSK-01, RSK-04; CRT-01	OSA Head	Preventive	Automated	Every login and record access	Implemented
CTL-02	Role-based access assigns each role a defined set of functions	RSK-01, RSK-04; CRT-01	OSA Head	Preventive	Automated	Every login	Implemented
CTL-03	Audit trail logs user, time, and action type for system activities	RSK-01, RSK-06; CRT-04	OSA Head	Detective	Automated	Every action	Implemented
CTL-04	Passwords are hashed; login requires password	RSK-04; CRT-01	OSA Head	Preventive	Automated	Every login	Implemented
CTL-05	Input validation rejects incomplete or invalid records	RSK-01, RSK-02; CRT-02, CRT-03	OSA Head	Preventive	Automated	Every record save	Implemented
CTL-06	Rule-based early warning	RSK-02; CRT-03	OSA Head	Detective	Automated	Per attendance	Partial

	flags at-risk students					/violation update	
CTL-07	Manual review by OSA Staff before intervention	RSK-02; CRT-03	OSA Head	Preventive	Manual	Per at-risk case	Partial
CTL-08	Role restrictions limit report export to authorized roles	RSK-07; CRT-04	OSA Head	Preventive	Automated	Every export attempt	Partial
CTL-09	Excel batch import validates data on import	RSK-01, RSK-02; CRT-02	OSA Head	Preventive	Automated	Per import	Implemented
CTL-10	In-system notifications alert users to at-risk triggers	RSK-02; CRT-03	OSA Head	Detective	Automated	Per at-risk trigger	Partial
CTL-11	Periodic access review by OSA Head	RSK-01; CRT-01	OSA Head	Preventive	Manual	Periodic	Partial
CTL-12	Database backup and restore capability (MOD-07)	RSK-03; CRT-02	OSA Head	Corrective	Not implemented	—	Inadequate
CTL-13	Retention and disposal policy	RSK-08; CMP-04	OSA Head	Preventive	Manual	—	Inadequate
CTL-14	Privacy notice issued to students	RSK-08; CMP-02	OSA Head	Preventive	Manual	—	Inadequate

5.2 Design Effectiveness Assessment

CTL ID	Risk / Criterion Addressed	Design Rating	Rationale / Gap	Reviewer
CTL-01	RSK-01, RSK-04; CRT-01	Adequate	Centralized module exists; login required; design clear	Russel A. Cabaluna
CTL-02	RSK-01, RSK-04; CRT-01	Adequate	Each role has defined function set; no MFA, but design clear	Russel A. Cabaluna
CTL-03	RSK-01, RSK-06; CRT-04	Partially Adequate	Logs exist but stored in same database; no integrity check	Ghyn Aedrianne Mendoza
CTL-04	RSK-04; CRT-01	Partially Adequate	Passwords hashed; no MFA	Ghyn Aedrianne Mendoza
CTL-05	RSK-01, RSK-02; CRT-02, CRT-03	Adequate	Forms require key fields and reject invalid input	Ghyn Aedrianne Mendoza
CTL-06	RSK-02; CRT-03	Partially Adequate	Rule-based warning exists but depends on partial Python tool	Russel A. Cabaluna
CTL-07	RSK-02; CRT-03	Partially Adequate	Manual review helps but no documented review steps	Russel A. Cabaluna
CTL-08	RSK-07; CRT-04	Partially Adequate	Roles limit export but no written rules or export log	Ghyn Aedrianne Mendoza
CTL-09	RSK-01, RSK-02; CRT-02	Adequate	Batch import exists; validation applied	Ghyn Aedrianne Mendoza
CTL-10	RSK-02; CRT-03	Partially Adequate	Notifications exist but depend on partial Python tool	Russel A. Cabaluna

CTL-11	RSK-01; CRT-01	Partially Adequate	Access review mentioned but no schedule or proof	Russel A. Cabaluna
CTL-12	RSK-03; CRT-02	Inadequate	Control does not exist; MOD-07 planned only	Jasmin T. Pille
CTL-13	RSK-08; CMP-04	Inadequate	No retention or disposal policy exists	Jasmin T. Pille
CTL-14	RSK-08; CMP-02	Inadequate	No privacy notice exists	Jasmin T. Pille

5.3 Test Plan and Results

TEST ID	CTL / RSK	Population / Period	Sample Method / Size	Procedure	Expected Result	Actual Result / Exceptions	Evidence	Conclusion
TEST-01	CTL-01 / RSK-01	All student profile records in demo build	Purposive — inspect module	Inspect profile module and confirm complete records stored in one place	All key student fields stored in one module	Profile module stores personal, academic, and disciplinary fields	EVD-10-02	Effective
TEST-02	CTL-02 / RSK-01, RSK-04	All 5 user roles (ACC-01 to ACC-05)	Purposive — all 5 roles	Inspect role matrix and walk through one allowed action per role	Each role only sees allowed functions	All 5 roles matched assigned functions; no extra access found	EVD-10-01	Effective
TEST-03	CTL-03 / RSK-06	Audit trail logs for 5 sample admin actions	Purposive — 5 recent actions	Inspect audit trail; confirm user, time, action type	Each admin action logged with user and time	Logs show user and time for all 5; logs can be edited by DB-level users	EVD-10-06	Partially Effective
TEST-04	CTL-04 / RSK-04	All 6 user accounts	Purposive — all 6 accounts	Inspect password handling and login flow; confirm MFA	Passwords hashed; login requires password only	Passwords hashed; no MFA, no lockout, no session timeout	EVD-10-01, FLOW-01	Partially Effective
TEST-05	CTL-05 / RSK-01, RSK-02	100 sample records across modules	Purposive — 100 records	Save one record per module with missing/invalid data; check rejection	System rejects incomplete or invalid records	All 5 samples rejected when required fields missing or invalid	EVD-10-02 to EVD-10-05	Effective
TEST-06	CTL-06 / RSK-02	At-risk detection rules in demo build	Purposive — 3 test cases	Test rule-based early warning with dummy attendance and violation data	System flags at-risk students based on rules	System flagged 3 test cases correctly; depends on partial Python tool	EVD-10-05	Partially Effective
TEST-07	CTL-07 / RSK-02	At-risk dashboard for current test data	Purposive — 1 dashboard review	Walk through at-risk review and confirm manual check before intervention	Manual review happens before intervention	Manual review happens but no written procedure	EVD-10-05	Partially Effective
TEST-08	CTL-08 / RSK-07	2 user roles — export function	Purposive — 2 roles	Try to access export as each role; check restrictions	Only OSA Head and OSA Staff can export	OSA Staff, Faculty, Chairperson, Security Guard could not export; no export log	EVD-10-06	Partially Effective
TEST-09	CTL-09 / RSK-01, RSK-02	Excel batch import function	Purposive — 1 test import	Import dummy student data via Excel; check validation	Valid data imported; invalid data rejected	Valid data imported; invalid data rejected	EVD-10-02	Effective
TEST-10	CTL-10 / RSK-02	In-system notifications	Purposive — 1 test trigger	Trigger at-risk rule and check notification	Notification appears in system	Notification appeared; depends on partial Python tool	EVD-10-05	Partially Effective
TEST-11	CTL-11 / RSK-01	All 6 accounts (ACC-01 to ACC-06)	Purposive — all accounts	Ask owner for last access review date and inspect review record	Recent access review exists with evidence	No review record found; review mentioned but not proven	None (limit)	Not Tested

TEST-12	CTL-12 / RSK-03	Backup function (MOD-07)	Not tested — no control	Inspect build for backup tool	Backup exists and restore tested	No backup tool in build; MOD-07 planned only	None	Not Tested (uncontrolled gap)
TEST-13	CTL-13 / RSK-08	Retention and disposal process	Not tested — no control	Ask owner for retention or disposal policy	Written policy exists	No policy provided	None	Not Tested (uncontrolled gap)
TEST-14	CTL-14 / RSK-08	Privacy notice for students	Not tested — no control	Ask owner for privacy notice given to students	Privacy notice exists and issued	No privacy notice provided	None	Not Tested (uncontrolled gap)

5.4 Detailed Test Note — TEST-02

Field	Entry
Selected TEST ID	TEST-02
Tester	Mendoza, Ghyn Aedrianne
Date / Time	10/3/2026, 2:00 PM
Environment	Local XAMPP demo build
Authorization	Authorized by OSA Head for non-destructive walkthrough using dummy accounts
Procedure	Inspected role matrix (EVD-10-01) and walked through one allowed action per role: OSA Head (edit student), OSA Staff (view records), Faculty Adviser (record attendance), Security Guard (record violation)
Sample Identifiers	ACC-01, ACC-02, ACC-03, ACC-04
Actual Observations	Each role only reached its allowed functions; no role could open a function outside its scope
Exception Handling	No exceptions found
Evidence IDs	EVD-10-01
Limitation	Walkthrough used dummy data only; no production test
Reviewer / Performance	Russel Cabaluna reperformed one action (OSA Staff view) and got same result
Final Conclusion	Effective
Selected TEST ID	TEST-02

5.5 Gap Register

GAP ID	Affected CTL / TEST	Related RSK / CMP / CRT	Gap or Limitation	Evidence	Impact / Priority	Owner	Candidate Finding?
GAP-01	CTL-03 / TEST-03	RSK-06; CRT-04	Audit logs can be changed or deleted by DB-level users; no integrity check	EVD-10-06; ACC-07 note	Medium	OSA Head	No — needs more evidence; observation
GAP-02	CTL-04 / TEST-04	RSK-04; CRT-01	No MFA	EVD-10-01, FLOW-01	High	OSA Head	Yes — material access weakness
GAP-03	CTL-06, CTL-10 / TEST-06, TEST-10	RSK-02; CRT-03	Rule-based warning and notifications depend on partial Python tool	EVD-10-05; AST-10	High	OSA Head	Yes — material risk to at-risk detection
GAP-04	CTL-08 / TEST-08	RSK-07; CRT-04	No written export rules and no export log	EVD-10-06	Medium	OSA Head	No — needs more evidence; observation
GAP-05	CTL-11 / TEST-11	RSK-01; CRT-01	Access review mentioned but no schedule or proof	None (limitation)	Medium	OSA Head	No — evidence limitation
GAP-06	CTL-12 / TEST-12	RSK-03; CRT-02	No backup tool in build; MOD-07 planned only	None	High	OSA Head	Yes — uncontrolled high risk

GAP-07	CTL-13 / TEST-13	RSK-08; CMP-04	No retention and disposal policy	None	Medium	OSA Head	Yes — privacy gap
GAP-08	CTL-14 / TEST-14	RSK-08; CMP-02	No privacy notice issued to students	None	Medium	OSA Head	Yes — privacy gap
GAP-09	CTL-03 / TEST-03	RSK-06; CRT-04	Audit trail completeness not fully verified for whole period	EVD-10-06	Low	OSA Head	No — limitation only

5.6 Control Domain Coverage Summary

Control Domain	Relevant Risks	Controls Identified	Tests Performed	Effective / Partial / Ineffective / Not Tested	Material Gaps / Limits
Governance	RSK-08; CMP-02, CMP-04	CTL-13, CTL-14	TEST-13, TEST-14	0/0/0/2	GAP-07, GAP-08 — no policy, no notice
Access	RSK-01, RSK-04; CRT-01	CTL-01, CTL-02, CTL-04, CTL-11	TEST-01, TEST-02, TEST-04, TEST-11	2/1/0/1	GAP-02, GAP-05 — no MFA, no review proof
Application Processing	RSK-01, RSK-02; CRT-02, CRT-03	CTL-05, CTL-06, CTL-07, CTL-09, CTL-10	TEST-05, TEST-06, TEST-07, TEST-09, TEST-10	2/3/0/0	GAP-03 — partial Python tool
Data / Privacy	RSK-05, RSK-07, RSK-08; CMP-01, CMP-04	CTL-08, CTL-13, CTL-14	TEST-08, TEST-13, TEST-14	0/1/0/2	GAP-04, GAP-07, GAP-08
Logging / Monitoring	RSK-01, RSK-06; CRT-04	CTL-03	TEST-03	0/1/0/0	GAP-01, GAP-09
Change	None identified	None	—	Not tested — outside Lab 10 scope	—
Incident	RSK-06	None identified	—	—	No incident process (linked to RSK-06)
Backup / Recovery	RSK-03; CRT-02	CTL-12	TEST-12	0/0/0/1	GAP-06 — uncontrolled high risk
Infrastructure	RSK-05	None identified	—	—	Local prototype only

6. FINDINGS, RECOMMENDATIONS, AND PROPOSED MANAGEMENT ACTION PLAN

6.1 Finding Candidate Screening

Candidate ID	Source GAP / TEST	Evidence Sufficient?	Material?	Within Scope?	Decision	Rationale
FC-01	GAP-02 / TEST-04	Yes — EVD-10-01, FLOW-01	Yes	Yes	Finding	No MFA for privileged users is a material access weakness

FC-02	GAP-03 / TEST-06, TEST-10	Yes — EVD-10-05, AST-10	Yes	Yes	Finding	Partial Python tool affects at-risk detection and notifications
FC-03	GAP-06 / TEST-12	Yes — AST-11	Yes	Yes	Finding	No backup tool is a high risk to data availability
FC-04	GAP-07 / TEST-13	Yes — FLOW-02 to FLOW-05	Yes	Yes	Finding	No retention policy is a privacy gap
FC-05	GAP-08 / TEST-14	Yes — data inventory	Yes	Yes	Finding	No privacy notice is a transparency gap
FC-06	GAP-01 / TEST-03	Yes — EVD-10-06, ACC-07	Partially	Yes	Observation	Log integrity weakness — needs more evidence for formal finding
FC-07	GAP-04 / TEST-08	Yes — EVD-10-06	Partially	Yes	Observation	No export log or written rules — needs more evidence
FC-08	GAP-05 / TEST-11	No — no evidence	No	Yes	Close	Access review not proven; limitation only
FC-09	GAP-09 / TEST-03	Yes — EVD-10-06	No	Yes	Close	Audit trail completeness not fully verified — low impact only

6.2 Finding Summary Register

Candidate ID	Source GAP / TEST	Evidence Sufficient?	Material?	Within Scope?	Decision	Rationale
FND-01	No MFA for privileged accounts increases risk of unauthorized access to sensitive student records	RSK-04, CTL-04, TEST-04, GAP-02, ACC-01, ACC-02, ACC-05, FLOW-01	High	EVD-10-01, FLOW-01	REC-01	Draft
FND-02	Partial Python analytics tool may cause at-risk students to be misclassified and miss interventions	RSK-02, CTL-06, CTL-10, TEST-06, TEST-10, GAP-03, AST-10, MOD-03	High	EVD-10-05, AST-10	REC-02	Draft
FND-03	No database backup tool means permanent data loss is possible after system failure	RSK-03, CTL-12, TEST-12, GAP-06, AST-11, MOD-07	High	AST-11, DEP-07	REC-03	Draft
FND-04	No retention and disposal policy means student records may be kept longer than necessary	RSK-08, CTL-13, TEST-13, GAP-07, CMP-04, FLOW-02 to FLOW-05	Moderate	FLOW-02 to FLOW-05	REC-04	Draft

FND-05	No privacy notice means students are not informed why their data is collected	RSK-08, CTL-14, TEST-14, GAP-08, CMP-02, DATA (all)	Moderate	Data inventory	REC-05	Draft

6.3 Detailed Finding Workpapers

FND-01 — No MFA for Privileged Accounts

Field	Entry	
Finding ID / Title	FND-01	No MFA for privileged accounts increases risk of unauthorized access to sensitive student records
Severity / Rationale	High	RSK-04 is High. Password-only login is a single point of failure for administrative and staff accounts with broad access.
Affected Scope / IDs	SCP-01, ACC-01, ACC-02, ACC-05, MOD-01, RSK-04, CTL-04, TEST-04, GAP-02, FLOW-01	
Condition	During testing (TEST-04), all 6 accounts were inspected. Passwords are hashed, but login requires only a password. No MFA, lockout, or session timeout was observed.	
Criteria	CRT-01 — role-based access requirements; CMP-01 — DPA Section 20 security of personal information	
Cause	MFA was not included in the prototype. Root cause: missing security control.	
Effect / Risk	A stolen password can allow unauthorized access to student records, violations, and interventions. Affects confidentiality and integrity of student data.	
Evidence	EVD-10-01 role matrix; FLOW-01 login flow	
Recommendation	Add MFA for privileged accounts and implement account lockout and session timeout. See REC-01.	
Scope / Evidence Limitation	Tested on demo build only; no production authentication test performed.	

Finding Narrative and Auditor Analysis: SPEWS uses username-and-password authentication for all accounts, including OSA Head and OSA Staff accounts with broad add/edit/delete privileges. No MFA, lockout, or session timeout was observed. Because a single stolen password could grant access to sensitive student records, this is a High finding. The issue is a missing preventive control, not a failed existing control.

FND-02 — Partial Python Analytics Tool

Field	Entry	
Finding ID / Title	FND-02	Partial Python analytics tool may cause at-risk students to be misclassified and miss interventions
Severity / Rationale	High	RSK-02 is High. At-risk detection is a core system objective; misclassification could cause students to miss help.
Affected Scope / IDs	SCP-02, SCP-07, AST-10, MOD-03, RSK-02, CTL-06, CTL-10, TEST-06, TEST-10, GAP-03	
Condition	During testing (TEST-06, TEST-10), rule-based warning worked for simple cases, but the Python tool for the 20% attendance threshold and Low/Medium/High classification is partial.	
Criteria	CRT-03 — records should reflect documented rules; capstone requirement — early detection of at-risk students	
Cause	Python analytics component is still in progress. Root cause: unfinished development.	
Effect / Risk	At-risk students may be labeled wrong and miss interventions. Affects students most in need of help.	
Evidence	EVD-10-05 at-risk dashboard; AST-10 shows "Planned / In Progress"	
Recommendation	Complete and test the Python tool before full use. Add manual review steps. See REC-02.	
Scope / Evidence Limitation	Tested on demo build only; Python tool is partial, so results are limited.	

Finding Narrative and Auditor Analysis: The early warning system is a core objective of SPEWS. Testing showed the rule-based warning works for simple cases. However, the Python tool that calculates the 20% attendance threshold and classifies students as Low/Medium/High is still partial. This means some at-risk students may not be flagged correctly. The issue is a development gap, not a failure of an existing control. Manual review by OSA Staff helps, but it is not a verified safeguard.

FND-03 — No Database Backup Tool

Field	Entry	
Finding ID / Title	FND-03	No database backup tool means permanent data loss is possible after system failure
Severity / Rationale	High	RSK-03 is High. Without backup, student, attendance, violation, and intervention records can be lost forever.
Affected Scope / IDs	SCP-06, AST-03, AST-11, MOD-07, RSK-03, CTL-12, TEST-12, GAP-06, DEP-07	

Condition	During testing (TEST-12), the build was inspected. No backup tool exists. MOD-07 is planned only (AST-11).	
Criteria	Capstone requirement — data availability; CRT-02 — implemented functions should match declared scope	
Cause	Backup module was not yet built. Root cause: missing control.	
Effect / Risk	A system crash or data damage could cause permanent loss of all student monitoring records. Affects OSA operations and student monitoring.	
Evidence	AST-11 shows "Not implemented"; DEP-07 assumption confirms no backup	
Recommendation	Build the backup tool (MOD-07) and test restore. See REC-03.	
Scope / Evidence Limitation	Backup is out of scope in Lab 7 (SCP-06). Finding is based on absence of control, not a failed test.	

Finding Narrative and Auditor Analysis: SPEWS stores all student monitoring records in a local MySQL database. There is no backup tool in the audited build. This means a system failure, corruption, or accidental deletion could permanently destroy student, attendance, violation, and intervention data. Because the data is critical to OSA operations, this is a High finding. The issue is a missing control — the backup module is planned but not implemented.

FND-04 — No Retention and Disposal Policy

Field	Entry	
Finding ID / Title	FND-04	No retention and disposal policy means student records may be kept longer than necessary
Severity / Rationale	Moderate	RSK-08 is Moderate. Keeping data too long is a privacy risk, but no breach has occurred.
Affected Scope / IDs	AST-04, AST-05, AST-06, AST-07, FLOW-02 to FLOW-05, RSK-08, CTL-13, TEST-13, GAP-07, CMP-04	
Condition	During testing (TEST-13), the owner was asked for a retention or disposal policy. No policy was provided.	
Criteria	DPA RA 10173 Section 20 — retention and disposal; CMP-04 — do not keep personal data longer than needed	
Cause	No policy was written. Root cause: governance gap.	
Effect / Risk	Student records may be kept indefinitely, increasing privacy risk. Affects students and OSA compliance.	

Evidence	FLOW-02 to FLOW-05 say "Retained per institutional policy" but no policy was given.	
Recommendation	Write a retention and disposal policy. See REC-04.	
Scope / Evidence Limitation	Status is "Not Determined" because no policy was provided. Cannot confirm noncompliance — only that evidence is missing.	

Finding Narrative and Auditor Analysis: SPEWS stores student records, attendance, violations, and interventions. Lab 8 data flows say records are "retained per institutional policy," but no such policy was provided during testing. Without a written retention and disposal policy, records may be kept longer than necessary, which is a privacy risk under the DPA. This is a Moderate finding because no breach has occurred, but the gap is material to privacy compliance.

FND-05 — No Privacy Notice

Field	Entry	
Finding ID / Title	FND-05	No privacy notice means students are not informed why their data is collected
Severity / Rationale	Moderate	RSK-08 is Moderate. Transparency is a legal requirement, but no harm has occurred yet.
Affected Scope / IDs	AST-04, AST-05, AST-06, AST-07, DATA (all), FLOW-02 to FLOW-05, RSK-08, CTL-14, TEST-14, GAP-08, CMP-02	
Condition	During testing (TEST-14), the owner was asked for a privacy notice given to students. None was provided.	
Criteria	DPA RA 10173 Section 11 — transparency; CMP-02 — tell people why their data is collected	
Cause	No privacy notice was written. Root cause: governance gap.	
Effect / Risk	Students are not informed how their data is used. Affects student rights and OSA transparency.	
Evidence	Data inventory shows personal data collected, but no notice was provided.	
Recommendation	Create and give a privacy notice to students. See REC-05.	
Scope / Evidence Limitation	Status is "Not Determined" because no notice was provided. Cannot confirm noncompliance — only that evidence is missing.	

Finding Narrative and Auditor Analysis: SPEWS collects student personal data for profiling, attendance, violations, and interventions. Under the DPA, students should be told why their data is collected. No privacy notice was provided during testing. This is a Moderate finding because transparency is a legal requirement, but no harm has occurred. The issue is a missing governance control, not a failed system control.

6.4 Recommendation Register

REC ID	FND ID	Recommended Action	Accountable Role	Priority	Effort / Dependencies	Target Result	Validation Measure
REC-01	FND-01	Add MFA, lockout after failed attempts, and session timeout	OSA Head	High	Medium effort; depends on dev time	Privileged accounts protected by two factors	MFA enabled and tested; lockout and timeout confirmed
REC-02	FND-02	Complete the Python analytics tool; test 20% attendance and Low/Medium/High rules; add manual review steps	OSA Head	High	High effort; depends on dev team	At-risk students classified correctly	Python tool tested; manual review documented
REC-03	FND-03	Build the backup tool (MOD-07); test restore procedure	OSA Head	High	Medium effort; depends on dev time	Student records recoverable after failure	Backup runs and restore test passed
REC-04	FND-04	Write a retention and disposal policy; include archive/delete steps	OSA Head	Medium	Low effort; policy writing	Records kept only as long as needed	Policy approved and followed
REC-05	FND-05	Create and issue a privacy notice to students; explain purpose of data collection	OSA Head	Medium	Low effort; policy writing	Students informed of data use	Notice issued and acknowledged

6.5 Proposed Management Action Plan

MAP ID	REC ID	FND ID	Action	Accountable Role	Target / Trigger	Expected Risk Reduction	Follow-Up Evidence
MAP-01	REC-01	FND-01	Configure MFA for privileged accounts	OSA Head	Within 30 days	Stops stolen passwords from working	Screenshot of MFA settings
MAP-02	REC-01	FND-01	Configure lockout and session timeout	OSA Head	Within 30 days	Limits brute-force and session misuse	Screenshot of lockout and timeout settings
MAP-03	REC-02	FND-02	Complete Python tool and	OSA Head	Within 60 days	Ensures at-risk students are identified	Python tool test results

			test 20% rule				
MAP-04	REC-02	FND-02	Document manual review procedure	OSA Head	Within 60 days	Adds verified safeguard	Approved review procedure
MAP-05	REC-03	FND-03	Build backup tool (MOD-07)	OSA Head	Within 60 days	Prevents permanent data loss	Backup tool deployed
MAP-06	REC-03	FND-03	Run and document restore test	OSA Head	Within 60 days	Confirms recoverability	Restore test log
MAP-07	REC-04	FND-04	Write and approve retention and disposal policy	OSA Head	Within 90 days	Ensures lawful retention	Approved policy document
MAP-08	REC-05	FND-05	Draft and issue privacy notice	OSA Head	Within 90 days	Students informed of data use	Copy of issued notice

6.6 High-Risk Item Without Finding Review

RSK ID	Risk Level	Why No Finding	Supporting Control / Test / Evidence or Limitation	Required Disclosure / Follow-Up
RSK-06	High	Log integrity is an observation only because evidence is insufficient for a formal finding	ACC-07 shows integrity depends on DB controls	Disclose as observation; future audit should test log integrity
RSK-07	High	Export rules are an observation only because no written rules were available to compare against	EVD-10-06 shows export exists but no rules were given	Disclose as observation; future audit should review export rules

7. AI VALIDATION PORTFOLIO

7.1 Consolidated Material AI-Use Register

AI ID	Lab / Section	Tool / Purpose	Material Output Used	Evidence / Criteria / Test Used to Validate	Decision	Revision / Rationale	Privacy / Bias Check	Reviewer / Date
AIV-01	Lab 8 / Assets	ChatGPT / Group assets	Grouped assets by type and	Lab 7 scope and	Accept	None needed; matched	No private data shared	Mendoza / 9/10/2026

			mapped to MOD IDs	Capstone PDF		3-tier architecture		
AIV-02	Lab 9 / Risks	ChatGPT / Suggest risks	Suggested login, access, backup, privacy risks	Lab 8 evidence and Lab 7 scope	Accept	None needed; risks matched observed conditions	No private data shared	Cabaluna / 9/26/2026
AIV-03	Lab 9 / Compliance	ChatGPT / Map DPA	Suggested DPA sections for security, transparency, rights	RA 10173 IRR	Revise	Fixed applicability to SPEWS; added "Not Determined" where proof missing	No private data shared	Mendoza / 9/26/2026
AIV-04	Lab 10 / Controls	ChatGPT / Test plan	Suggested test steps for access and reporting	Lab 9 risks and objectives	Accept	Used as guide only; team performed actual testing	No private data shared	Pille / 10/03/2026
AIV-05	Lab 11 / Findings	ChatGPT / Suggest findings	Suggested FND-01 to FND-05 based on gaps	Lab 10 GAP records	Revise	Kept findings but fixed severity ratings to match evidence	No private data shared	Cabaluna / 10/10/2026
AIV-06	Lab 11 / Recommendations	ChatGPT / Suggest actions	Suggested REC and MAP actions	Capstone objectives	Revise	Changed owners and target dates to match OSA roles	No private data shared	Pille / 10/10/2026
AIV-07	All Labs / Grammar	Grammarly / Check grammar	Fixed grammar in drafts	Draft text	Accept	Grammar only; no IDs or technical content changed	No private data shared	All / 10/17/2026
AI-14-01	Lab 12 / Format	ChatGPT / Format final report	Suggested format for executive summary and traceability matrix	Lab 11 final draft	Accept	Used format as guide; content written by team	No sensitive data shared	Pille / 10/17/2026

7.2 AI Validation Summary

Metric	Count
Material AI Uses Reviewed	8
Accepted Without Change	5
Revised	3
Rejected	0
Privacy Incidents / Corrective Action	None. No real student data was entered into AI tools.
Unresolved AI-Related Limitations	None. All AI output was checked against evidence.

7.3 AI Use and Human Accountability Disclosure

We used AI tools (ChatGPT and Grammarly) to help organize content, suggest risks, check compliance rules, and improve grammar. We did not treat AI output as audit evidence. Every AI suggestion was reviewed by a team member against evidence from Labs 7–10. We corrected AI when it produced errors, such as incorrect risk scores or target dates. No private student data or passwords were shared with AI tools. The team remains fully responsible for every conclusion in this report.

8. END-TO-END TRACEABILITY AND RECONCILIATION

8.1 Objective-to-Conclusion Traceability Matrix

OBJ	Scope / Criteria	Assets / Data / Users	Risks / Compliance	Controls / Tests / Evidence	Findings / Recommendations	Conclusion / Limitation
OBJ-01	SCP-01 / CRT-01	AST-02, AST-12, USR-01, USR-02	RSK-01, RSK-04, CMP-01	CTL-01, TEST-04, EVD-10-01	FND-01 / REC-01	Access control needs improvement due to no MFA
OBJ-02	SCP-02 / CRT-02	AST-02, MOD-01 to MOD-06	RSK-02, CMP-06	CTL-06, TEST-06, EVD-10-05	FND-02 / REC-02	Core system works but Python tool is partial
OBJ-03	SCP-03 / CRT-03	AST-03, AST-04, AST-05	RSK-03, RSK-05, CMP-01	CTL-12, TEST-12, AST-11	FND-03 / REC-03	Data at risk because backup is missing
OBJ-04	SCP-04 / CRT-04	DATA (all), FLOW-02 to FLOW-05	RSK-08, CMP-02, CMP-04	CTL-13, TEST-13, FLOW-02	FND-04 / REC-04	Privacy compliance weak due to no policy
OBJ-05	SCP-05 / CRT-05	DATA (all), USR-01 to USR-04	RSK-08, CMP-02	CTL-14, TEST-14, Data inventory	FND-05 / REC-05	Transparency missing due to no privacy notice

8.2 Finding and Action Reconciliation

FND ID	Severity	Supporting RSK / CTL / TEST / GAP / EVD	REC ID	MAP / Owner / Target	Current Status	Final Follow-Up Measure
FND-01	High	RSK-04, CTL-04, TEST-04, GAP-02, EVD-10-01	REC-01	MAP-01 to 02 / OSA Head / 30 days	Proposed	Check if MFA and lockout are enabled
FND-02	High	RSK-02, CTL-06, TEST-06, GAP-03, EVD-10-05	REC-02	MAP-03 to 04 / OSA Head / 60 days	Proposed	Test Python tool and manual review
FND-03	High	RSK-03, CTL-12, TEST-12, GAP-06, AST-11	REC-03	MAP-05 to 06 / OSA Head / 60 days	Proposed	Check backup runs daily and restore works
FND-04	Moderate	RSK-08, CTL-13, TEST-13, GAP-07, CMP-04	REC-04	MAP-07 / OSA Head / 90 days	Proposed	Check if retention policy is approved
FND-05	Moderate	RSK-08, CTL-14, TEST-14, GAP-08, CMP-02	REC-05	MAP-08 / OSA Head / 90 days	Proposed	Check if privacy notice is issued

8.3 High-Risk Item Without Finding Review

RSK ID	Risk Level	Why No Finding	Supporting Control / Test / Evidence or Limitation	Required Disclosure / Follow-Up
RSK-06	High	Log integrity is an observation only because evidence is insufficient for a formal finding	ACC-07 shows integrity depends on DB controls	Disclose as observation; future audit should test log integrity
RSK-07	High	Export rules are an observation only because no written rules were available	EVD-10-06 shows export exists but no rules were given	Disclose as observation; future audit should review export rules

9. EVIDENCE INDEX, APPENDICES, AND REFERENCES

9.1 Final Evidence Index

EVD ID	Title / Description	Source / Owner	Date / Version	Related IDs	Location / Access	Privacy Treatment	Reliability / Limitation
EVD-10-01	Sanitized user role matrix and access approval screenshot	OSA Head	9/26/2026	ACC-01 to 04, MOD-01	Team Drive	Sanitized	May not show full history
EVD-10-02	Student profile screenshot and database schema	OSA Head	9/26/2026	AST-02, AST-03, AST-04, MOD-02	Team Drive	Sanitized	Demo only
EVD-10-03	Attendance recording test records and screenshots	Faculty	9/26/2026	AST-05, MOD-03	Team Drive	Sanitized	Python calculation partial
EVD-10-04	Violation recording test records and screenshots	Security Guard	9/26/2026	AST-06, MOD-04	Team Drive	Sanitized	May not cover all scenarios
EVD-10-05	At-risk dashboard and intervention records	OSA Head	9/26/2026	AST-07, MOD-05	Team Drive	Sanitized	Depends on test data
EVD-10-06	Report export screenshot and audit trail sample	OSA Head	9/26/2026	AST-08, AST-09, MOD-06	Team Drive	Sanitized	Not production data
EVD-10-07	Build freeze note and version register	OSA Head	9/26/2026	BLD-01, all MOD	Team Drive	Internal	Confirms audited build version

9.2 Appendix and Reference Register

Appendix / Ref ID	Title	Purpose	Included / Controlled Separately	Confidentiality Treatment	Related Sections / IDs
REF-01	Data Privacy Act of 2012 (RA 10173)	Legal basis for privacy findings	Separately	Public	CMP-01 to CMP-07
REF-02	Capstone Design Document	System rules and architecture	Controlled	Academic	OBJ-01 to OBJ-05
APP-A	Lab 7 Scope Spreadsheet	Shows original scope	Separately	Academic	SCP-01 to SCP-08
APP-B	System Architecture and Data Flow Diagrams	Architecture reference	Included	Academic	DEP-01 to DEP-07, FLOW-01 to FLOW-07

10. FINAL INDEPENDENT QUALITY REVIEW

Review ID	Reviewer	Independent Review Assignment	Result / Exceptions	Resolution Evidence	Sign-Off / Date
FIN-01	Russel A. Cabaluna	Review narrative coherence and executive summary	Pass	No exceptions	Cabaluna / 10/17/2026
FIN-02	Ghyan Aedrianne Mendoza	Review traceability, counts, and ratings	Pass	Fixed ID mismatch on RSK-06	Mendoza / 10/17/2026
FIN-03	Jasmin T. Pille	Review AI validation, evidence, and privacy	Pass	Confirmed no real data leaked	Pille / 10/17/2026

10.1 Final Submission Checklist

☑ All Labs 9–13 instructor feedback is closed or disclosed as an unresolved limitation.
☑ The final build, environment, audit/evidence cutoff, report date, and changes after cutoff are stated.
☑ The table of contents and all tables/figures, headings, page numbers, cross-references, IDs, totals, and ratings are updated.
☑ Every material AI use is disclosed, independently validated, privacy-checked, and accepted/revised/rejected with rationale.
☑ End-to-end traceability contains no broken, duplicated, orphaned, or contradictory records.
☑ The executive summary and conclusion agree with detailed evidence, findings, severity totals, limitations, and proposed actions.
☑ Sensitive data, credentials, confidential prompts, unnecessary personal data, comments, and unused template placeholders are removed.
☑ All three members completed independent full-report review, resolved exceptions, signed the final attestation, and verified the DOCX/PDF export.

11. CROSS-MEMBER CHALLENGE RECORD

Review ID	Prepared By	Reviewed By	Item / Section	Challenge or Check	Resolution / Evidence
REV-14-01	Cabaluna	Mendoza	Executive Summary	Does the summary match the actual findings count?	Yes. Checked against FND-01 to FND-05. Count is correct.

REV-14-02	Mendoza	Pille	8.1 Matrix	Are all OBJ links complete?	Yes. Checked OBJ-01 to OBJ-05. All link to a finding or conclusion.
REV-14-03	Pille	Cabaluna	AI Register	Did we include all AI tools used?	Yes. ChatGPT and Grammarly are logged. No other tools used.

12. GROUP ATTESTATION

We certify that this Final Integrated Professional IT Audit Report reflects the identified capstone build and authorized evidence. We completed the assigned work and cross-review, protected confidential information, did not treat AI output as audit evidence, and disclosed material limitations.

Member	Printed Name	Signature	Date
Member 1	Russel A. Cabaluna	Cabaluna, Russel A.	10/17/2026
Member 2	Ghyan Aedrianne Mendoza	Mendoza, Ghyan Aedrianne	10/17/2026
Member 3	Jasmin T. Pille	Pille, Jasmin T.	10/17/2026

13. INSTRUCTOR REVIEW

Review Area	Status	Instructor Notes
Master-report continuity and prior feedback	[ ] Approved [ ] Revise	
Technical completeness and traceability	[ ] Approved [ ] Revise	
Evidence, limitations, collaboration, AI validation, and professional judgment	[ ] Approved [ ] Revise	